

PRUEBA TÉCNICA · CIBERSEGURIDAD

Arquitectura de Seguridad

As-Is / To-Be · Modelo C4 · Flujo del pipeline

PREPARADO POR	Lady Marcela Romero Rivero
ROL	Líder de Ciberseguridad
CLIENTE	Simon Movilidad
ESCENARIO	FleetSec S.A.S. — Telemetría de flotas
FECHA	25 de agosto de 2026
VERSIÓN	1.0

CONFIDENCIAL — Exclusivo para Simon Movilidad

Tabla de contenido

- 1. As-Is vs To-Be (security posture)**
- 2. Target architecture (C4 Container + trust boundaries)**
- 3. Incident data-flow (breach INC-2026-001)**
- 4. DevSecOps pipeline (fan-out / fan-in, ≤ 15 min)**

Author: Lady Marcela Romero Rivero · Líder de Ciberseguridad · Date: 2026-08-23 · Version: 1.0
All diagrams render natively on GitHub (Mermaid). For the draw.io canonical artifact, import the Mermaid source in draw.io: Arrange → Insert → Advanced → Mermaid.

1. As-Is vs To-Be (security posture)

Domain	AS-IS (today, no mature program)	TO-BE (target baseline)
Identity	IAM users, no MFA, admin on service accounts	SSO + MFA, STS, role-per-service, SCP guardrails
Edge	No WAF, port 80/443 direct	CloudFront + WAF v2 (SQLi/bad-inputs/rate/geo)
Network	Flat, public RDS, SG 0.0.0.0/0	3-tier VPC, isolated data subnet, no public RDS
Data	AES-256 default, partial BPA	SSE-KMS CMC, account BPA, Object Lock logs
Secrets	Hardcoded in source (V-10)	Secrets Manager, 30-day rotation
Logging	Regional trail, no validation, PII in logs	Multi-region trail + validation, PII masking
Detection	None	GuardDuty + Security Hub + Sigma rules + threat-intel set
SDLC	No security gates	DevSecOps pipeline (SAST/SCA/DAST/IaC/secrets), ≤15 min
IR	Ad-hoc	NIST 800-61 playbook, MITRE mapping, SIC path

2. Target architecture (C4 Container + trust boundaries)

Diagrama — versión navegable en el repositorio (Mermaid) y export draw.io/PNG.

Trust boundaries: TB1 internet→edge (WAF), TB2 edge→app (SG-app from ALB only), TB3→TB4 app→data (SG-data 5432 from SG-app only; data subnet has no internet route).

Data classification: RDS/S3 = **PII (Ley 1581)**; Secrets Manager = **secrets**; CloudTrail logs = **audit/immutable**.

3. Incident data-flow (breach INC-2026-001)

Diagrama — versión navegable en el repositorio (Mermaid) y export draw.io/PNG.

4. DevSecOps pipeline (fan-out / fan-in, ≤15 min)

Diagrama — versión navegable en el repositorio (Mermaid) y export draw.io/PNG.